

Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-07 09:00 WIB

Top 5 Highlights

- Personal Information for Over 1 Million People Stolen in a Cyberattack on Arizona's Court System
- A personnel file is a map: Why the FBI breach matters
- Changing the game: How AI forces organizations to revisit assumptions about recovery and resilience
- Ninja Forms plugin flaw exploited to hack WordPress sites
- Hackers exploit 32 zero-days on first day of Pwn2Own Ireland

Threat Intelligence (10)

01. Fake ChatGPT, Gemini, and Claude Ad Portals Capture Credentials and MFA Codes

Cybersecurity researchers have disclosed details of a "human-operated phishing platform" that impersonates advertising products for artificial intelligence (AI) chatbots like Google Gemini, Anthropic Claude, OpenAI ChatGPT, Perplexity, Meta Muse, and Manus. The products, which claim to offer campaign optimization, spend audits, and business-account connecti...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/10/fake-chatgpt-gemini-and-claude-ad.html>

02. Linux Backdoors Impersonate Email Security Tools to Evade Detection in Korea and Taiwan

Linux backdoors targeting telecom and network appliances in South Korea and Taiwan have been disguising their traffic as email services and seemingly legitimate processes to blend in and evade detection. Threat actors are known to name their malicious software after a legitimate operating system component or a process as a defense evasion measure. By borrow...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/10/linux-backdoors-impersonate-email.html>

03. Financial phishing campaigns exploit fragmented hosting, AI tools

U.S. financial services faced a significant surge in phishing attacks during the first half of 2026, with nearly 40,000 malicious URLs identified.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.scworld.com/brief/financial-phishing-campaigns-exploit-fragmented-hosting-ai-tools>

04. MCP fixed secret handling. URL elicitation moved the phishing risk into the browser

MCP URL elicitation protects secrets but shifts phishing risk into trusted browser flows.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/perspective/mcp-fixed-secret-handling-url-elicitation-moved-the-phishing-risk-into-the-browser>

05. Fake ChatGPT, Gemini Sites steal advertising accounts, MFA codes

A new campaign targeting ad account managers uses fake ChatGPT, Gemini, Claude, and Perplexity sites that steal login credentials and multi-factor authentication (MFA) codes through browser-in-browser attacks. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/fake-chatgpt-gemini-sites-steal-advertising-accounts-mfa-codes/>

06. Nikkei Discloses Two Employee Cloud Account Compromises

Nikkei says two employee cloud accounts were accessed, with one used to send 9,000 phishing emails

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/nikkei-employee-cloud-account/>

07. ISC Stormcast For Tuesday, October 6th, 2026

<https://isc.sans.edu/podcastdetail/10124>, (Tue, Oct 6th)

ISC Stormcast For Tuesday, October 6th, 2026 <https://isc.sans.edu/podcastdetail/10124>, (Tue, Oct 6th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33402>

08. Pacing the AI frontier won't solve agentic cybersecurity's most urgent problems

When Anthropic CEO Dario Amodei urged other leading AI labs to “pace the frontier” last week, his calls for caution were echoed by other prominent voices in tech. Both Sam Altman and Elon Musk agreed with Amodei’s assessment that pausing AI development was essential to prevent the extinction of the human race. Amodei listed several potential disasters that...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.csoononline.com/article/4230811/pacing-the-ai-frontier-wont-solve-agentic-cybersecuritys-most-urgent-problems.html>

09. Long-Running NPM Malware Campaign Accumulates 40,000 Downloads

Since August 2023, attackers have published eight malicious packages as part of the Malfex supply chain campaign. The post Long-Running NPM Malware Campaign Accumulates 40,000 Downloads appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://www.securityweek.com/long-running-npm-malware-campaign-accumulates-40000-downloads/>

10. Blinder Tunnel Campaign Targets Iraqi Infrastructure

Analysis of Blinder Tunnel, an Iran-nexus campaign using fake Dubai Airports recruitment lures and GitHub C2 malware to target critical infrastructure. The post Blinder Tunnel Campaign Targets Iraqi Infrastructure appeared first on Unit 42 .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://unit42.paloaltonetworks.com/blinder-tunnel-targets-critical-infrastructure/>

Latest Vulnerabilities (10)

01. Changing the game: How AI forces organizations to revisit assumptions about recovery and resilience

AI changes recovery plans because it is at once a threat accelerator, a new kind of critical infrastructure and a defensive tool.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/resource/changing-the-game-how-ai-forces-organizations-to-revisit-assumptions-about-recovery-and-resilience>

02. Ninja Forms plugin flaw exploited to hack WordPress sites

Hackers are exploiting stored cross-site scripting (XSS) vulnerabilities in two unrelated WordPress plugins, Ninja Forms and WPC Product Bundles for WooCommerce, to install backdoors and create rogue admin accounts. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/ninja-forms-plugin-flaw-exploited-to-hack-wordpress-sites/>

03. Hackers exploit 32 zero-days on first day of Pwn2Own Ireland

On the first day of the Pwn2Own Ireland 2026 competition, security researchers hacked the Samsung Galaxy S26 twice and earned \$388,500 after exploiting 32 zero-days. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hackers-exploit-32-zero-days-on-first-day-of-pwn2own-ireland/>

04. FBI removes contractor working with its PeopleSoft system after data breach, says report

The US Federal Bureau of Investigation has removed an Accenture contractor working on its PeopleSoft installation over their role in a data breach that exposed personal details of FBI employees, Reuters reported Monday. This is the first time that anyone other than the hacker group Shinyhunters that claimed responsibility for the breach has linked it to Peo...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4231356/fbi-removes-contractor-working-with-its-peoplesoft-system-after-data-breach-says-report.html>

05. Google's PageBreak AI Agent Finds 500 Flaws in Its Web Apps

The situation illustrates a trend toward using AI and deterministic validation to identify flaws and exploitability, and provide a risk assessment.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/application-security/google-pagebreak-ai-agent-500-flaws-web-apps>

06. [0day-rubbish] StreamSets Transformer 3.17.0 auth-mode none fallback and un-sandboxed ScalaDTransform execution to container root (8.1 primary)

Posted by disclosure via Fulldisclosure on Oct 06 0day Rubbish Research Team is publicly disclosing a vulnerability in StreamSets Transformer, the Spark-engine data-pipeline platform from StreamSets Inc. (subsequently acquired by IBM), verified on version 3.17.0 analysed from the official container image. Type: failing-open authentication plus un-sandboxed...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Oct/8>

07. [0day-rubbish] RCDevs WebADM 2.4.14 authenticated log viewer sid command injection to webadm uid 999 code execution (7.2)

Posted by disclosure via Fulldisclosure on Oct 06 0day Rubbish Research Team is publicly disclosing a vulnerability in RCDevs WebADM 2.4.14, Freeware Edition, the closed-source IAM/MFA management platform from RCDevs Security SA (Luxembourg) that fronts the vendor's OpenOTP, SpanKey and TiQR authentication products. Type: OS command injection (CWE-78, with...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Oct/7>

08. [0day-rubbish] Maian Cart 3.8 addBanners unrestricted banner upload to PHP webshell and administrator command execution (7.2 primary, PR:H)

Posted by disclosure via Fulldisclosure on Oct 06 0day Rubbish Research Team is publicly disclosing a vulnerability in Maian Cart 3.8, the self-hosted PHP shopping-cart system from Maian Media (Maian Script World), verified end to end against a real installation of that version. Type: unrestricted upload of a file with a dangerous type (CWE-434), realized a...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Oct/6>

09. [0day-rubbish] IPConfigure Orchid VMS 26.3.0 authenticated DNF repository GPG-key property command injection to root (7.2)

Posted by disclosure via Fulldisclosure on Oct 06 0day Rubbish Research Team is publicly disclosing a vulnerability in IPConfigure Orchid VMS, installed as Orchid Recorder, version 26.3.0. Type: OS command injection (CWE-78, with CWE-20 bearing on it because no character validation exists anywhere on the path; CWE-250 bears on the result). The server proper...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Oct/5>

10. [0day-rubbish] Circutor LineEds 24.11.14-r0 unauthenticated pwrstudio events.xml shellExecute command injection (9.8)

Posted by disclosure via Fulldisclosure on Oct 06 0day Rubbish Research Team is publicly disclosing a vulnerability in the pwrstudio daemon shipped in Circutor LineEds (Line Energy Data System) industrial energy gateway firmware 24.11.14-r0, engine variant pss0. Circutor S.A. is in Spain; the appliance sits between metering and power-quality instrumentation...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Oct/4>

Data Breach & Cybercrime (10)

01. Personal Information for Over 1 Million People Stolen in a Cyberattack on Arizona's Court System

The Arizona Supreme Court said the information was copied for people dating back as far as 30 years. The post Personal Information for Over 1 Million People Stolen in a Cyberattack on Arizona's Court System appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/personal-information-for-over-1-million-people-stolen-in-a-cyber-attack-on-arizonas-court-system/>

02. A personnel file is a map: Why the FBI breach matters

The government needs to protect personnel records as strongly as it protects its own secrets.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/perspective/a-personnel-file-is-a-map-why-the-fbi-breach-matters>

03. Phishing scam targets tourists applying for Schengen visas

A new phishing scam is targeting tourists applying for Schengen visas, with scammers sending fraudulent emails that mimic official communications from EU migration authorities.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/phishing-scam-targets-tourists-applying-for-schengen-visas>

04. ASOS confirms data breach after “HACKED” in-app notifications

UK fashion retailer ASOS confirmed a data breach Tuesday after hackers sent unauthorized push notifications through its mobile app while claiming to have stolen customer data from the company's Snowflake environment. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/asos-confirms-data-breach-after-hacked-in-app-notifications/>

05. ASOS “hackers” send push notifications to customers

ASOS customers received a push notification regarding a breach of the company. Here's what we know so far.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.malwarebytes.com/blog/news/2026/10/asos-hackers-send-push-notifications-to-customers>

06. FBI Arrests ‘Most Wanted’ Developer of Ploutus ATM Malware

An alleged leader of Tren de Aragua’s ATM jackpotting activities, Canelon Aguirre was on the FBI’s top 10 most wanted list since March 2026. The post FBI Arrests ‘Most Wanted’ Developer of Ploutus ATM Malware appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/fbi-arrests-most-wanted-developer-of-ploutus-atm-malware/>

07. Facebook Marketplace scam uses your name and number

Facebook users are reporting receiving a message with a fake Facebook Marketplace listing that has their name as the seller.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/10/facebook-marketplace-phish-uses-your-name-and-number>

08. Asos app delivers a data leak threat instead of fast fashion

Rogue notification claims Snowflake instance compromised, but customer info theft remains unverified

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/10/06/asos-app-delivers-a-data-leak-threat-instead-of-fast-fashion/5301332>

09. ASOS Customers Receive Bizarre “Hacked” Message Amid Suspected Snowflake Compromise

ASOS customers have received a seemingly legitimate push notifications claiming the retailer’s IT systems have been breached through a Snowflake breach

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/asos-customers-message-suspected/>

10. IronChain Ransomware Threatens Businesses with Permanent Data Loss and Costly Downtime

Editor’s note: This research was conducted by Himanshu Anand, an independent cybersecurity researcher (follow Himanshu on X). During Cybersecurity Awareness Month, ransomware remains one of the clearest examples of how a cyber incident can become a business continuity issue. IronChain shows why. It puts business-critical data at risk of permanent loss and c...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://any.run/cybersecurity-blog/ironchain-analysis/>